POLITEKNIK NEGERI BENGKALIS

Jurusan Teknik Informatika · Program Studi D4 Rekayasa Perangkat Lunak

JOBSHEET 3

Secure SDLC, Attack Surface dan Threat Modeling

Mata kuliah	Keamanan Perangkat Lunak
Pertemuan	3
Topik	Secure SDLC, Attack Surface & Threat Modeling
Praktikum	Analisis arsitektur login dan checkout Juice Shop: entry point, DFD, STRIDE
Output	Attack Surface Map + Threat Model (Bab 3)
Dosen pengampu	Muhammad Asep Subandri, M.Kom

A. Tujuan Praktikum

Setelah menyelesaikan jobsheet ini, mahasiswa mampu:

- Menjelaskan aktivitas keamanan pada setiap fase Secure SDLC.
- Mengidentifikasi entry point dan menyusun Attack Surface Map.
- Menggambar Data Flow Diagram (DFD) lengkap dengan trust boundary.
- Menerapkan STRIDE pada elemen DFD dan menyusun Threat Model.
- Menilai risk setiap threat dengan skala Pertemuan 2 dan menghubungkannya ke Asset & Risk Register.

B. Alat dan Bahan

Komponen	Keterangan
Target	OWASP Juice Shop (http://localhost:3000), dengan batas analisis pada fitur login dan checkout.
Pengamatan	Browser DevTools dan History pada OWASP ZAP (mode pasif).
Diagram	draw.io (diagrams.net) atau Mermaid. OWASP Threat Dragon bersifat opsional.
Masukan	Asset & Risk Register dari Bab 2 (ID aset A-xx dan risk R-xx).
Template	Tabel pada Lampiran A, B, dan C jobsheet ini.

C. Dasar Teori Singkat

1. Secure SDLC

Secure SDLC menanamkan aktivitas keamanan pada setiap fase pengembangan, bukan hanya pengujian di akhir. Prinsip shift-left: semakin awal celah ditemukan, semakin murah perbaikannya.

Fase	Aktivitas keamanan
Requirements	Security requirement dan abuse case
Design	Threat modeling dan review desain (fokus pertemuan ini)
Implementation	Secure coding dan code review
Testing	SAST, SCA, DAST, penetration test

Fase	Aktivitas keamanan
Deployment	Hardening dan review konfigurasi
Maintenance	Patch dependency dan incident response

2. Attack surface

Attack surface adalah seluruh titik tempat data atau perintah dapat masuk dan keluar dari sistem (entry point): antarmuka web, API, upload file, penyimpanan data, dependency, dan akun. Memperkecil attack surface berarti menghapus fitur yang tidak perlu, menerapkan least privilege, dan memvalidasi input di setiap entry point.

3. Threat modeling dan DFD

Threat modeling menjawab empat pertanyaan: apa yang kita bangun, apa yang bisa salah, apa yang akan kita lakukan, dan apakah sudah cukup baik. Pertanyaan pertama dijawab dengan DFD.

Elemen DFD	Keterangan
External entity (E)	Pihak di luar kendali sistem, misalnya pelanggan.
Process (P)	Kode yang mengolah data, misalnya API login.
Data store (D)	Tempat data disimpan, misalnya database.
Data flow (F)	Perpindahan data antar elemen.
Trust boundary	Batas perubahan tingkat kepercayaan. Data flow yang melewatinya adalah kandidat utama attack surface.

4. STRIDE

STRIDE adalah enam kategori ancaman. Setiap kategori melanggar satu properti keamanan.

Kategori	Properti dilanggar	Contoh pada Juice Shop
Spoofing	Authentication	Memakai identitas atau token milik orang lain
Tampering	Integrity	Mengubah harga atau jumlah pada request keranjang
Repudiation	Non-repudiation	Pelanggan menyangkal pesanan karena tidak ada log
Information disclosure	Confidentiality	Pesan error membocorkan stack trace
Denial of service	Availability	Bot membanjiri endpoint login
Elevation of privilege	Authorization	Pelanggan memanggil fungsi khusus admin

Kategori yang relevan bergantung pada jenis elemen (STRIDE per elemen):

Elemen	S	T	R	I	D	E
External entity	✓		✓			
Process	✓	✓	✓	✓	✓	✓
Data store		✓	✓ (bila ada log)	✓	✓	
Data flow		✓		✓	✓	

Attack surface bukan vulnerability. Entry point hanyalah pintu masuk. Threat model memetakan ancaman yang mungkin terjadi pada pintu itu, sedangkan vulnerability baru terbukti setelah diuji pada pertemuan berikutnya.

D. Langkah Praktikum

Batasan hari ini. Praktikum ini hanya **mengamati dan menganalisis**. Eksploitasi aktif belum dilakukan. Gunakan hanya Juice Shop di komputer Anda sendiri dan patuhi Rules of Engagement dari pertemuan 1. Gunakan data uji, bukan data pribadi yang nyata.

Langkah 1. Menentukan cakupan

1. Pastikan container berjalan (docker ps), lalu buka http://localhost:3000.
2. Login dengan akun uji milik Anda sendiri, tambahkan produk ke keranjang, lalu jalankan checkout dengan data uji.
3. Tulis satu paragraf cakupan: alur yang dianalisis, aktor, dan data yang diproses. Rujuk aset dari Bab 2 yang terlibat (A-xx).

Langkah 2. Menginventaris entry point

1. Jalankan ZAP lewat Launch Browser seperti pertemuan 1, lalu ulangi alur login dan checkout.
2. Pada tab History, saring request ke localhost:3000. Catat metode, URL, data yang dikirim, dan apakah request memerlukan login.
3. Tambahkan entry point dari antarmuka (form, kolom input, parameter URL). Isi Lampiran A dengan **minimal 10 entry point**.

Contoh pola yang mungkin Anda temukan (verifikasi pada History Anda, jangan disalin tanpa bukti):

```
# Contoh pola endpoint; nama dan path dapat berbeda antar versi
POST /rest/user/login          -> kredensial, tanpa token
GET  /rest/basket/<id>         -> perlu token, ada identifier pada URL
POST /rest/basket/<id>/checkout -> perlu token, memicu pembuatan pesanan
```

Langkah 3. Menggambar DFD

1. Tentukan elemen E, P, D, dan F, beri ID berurutan (E1, P1, D1, F1, dan seterusnya), lalu isi Lampiran B.
2. Gambar DFD level 1 di draw.io atau Mermaid. Sertakan **minimal satu trust boundary**.
3. Tandai setiap data flow yang melewati trust boundary.

Kerangka Mermaid sebagai titik awal (ubah sesuai temuan Anda):

```
%% DFD level 1: kerangka contoh, sesuaikan dengan temuan Anda
flowchart LR
  E1[E1 Pelanggan]                 %% external entity
  subgraph SERVER[Zona server]     %% trust boundary
    P1((P1 Login))                 %% process
    D1[(D1 Data akun)]             %% data store
  end
  E1 -- F1 kredensial --> P1       %% data flow lintas boundary
  P1 -- F3 query akun --> D1
```

Langkah 4. Menerapkan STRIDE

1. Untuk setiap elemen DFD, tinjau kategori STRIDE yang relevan menurut tabel STRIDE per elemen.
2. Tulis threat sebagai kalimat konkret (siapa melakukan apa pada elemen mana). Isi Lampiran C dengan **minimal 12 threat** yang mencakup **minimal 5 dari 6 kategori**.

3. Kaitkan setiap threat dengan aset (A-xx) dan, bila relevan, dengan risk R-xx dari Bab 2.

Langkah 5. Menilai risk dan menentukan respons

1. Beri Likelihood (1-5) dan Impact (1-5) dengan alasan singkat, lalu hitung skor L × I (Rendah 1-4, Sedang 5-9, Tinggi 10-14, Kritis 15-25).
2. Pilih respons: mitigate, accept, transfer, atau avoid. Untuk mitigate, tulis kontrol yang diusulkan.
3. Urutkan threat dari skor tertinggi.

Langkah 6. Refleksi

Tulis 3-4 kalimat: apa yang dapat ditemukan threat modeling pada fase desain yang sulit ditemukan setelah kode selesai?

E. Output dan Pengumpulan

Seluruh output menjadi **Bab 3** pada laporan berjalan. Kumpulkan dalam satu file PDF dengan nama NIM_Nama_Bab3.pdf.

No	Bagian laporan	Isi
1	Cakupan sistem	Satu paragraf: alur, aktor, data, dan aset terkait.
2	Attack Surface Map	Minimal 10 entry point (Lampiran A).
3	DFD	Gambar level 1 dengan ID elemen dan trust boundary, plus tabel Lampiran B.
4	Threat Model	Minimal 12 threat STRIDE dengan risk (Lampiran C).
5	Refleksi	3-4 kalimat.

F. Rubrik Penilaian

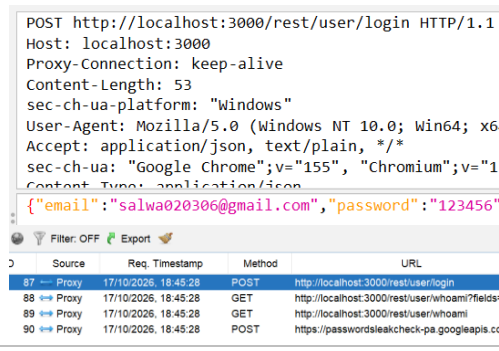
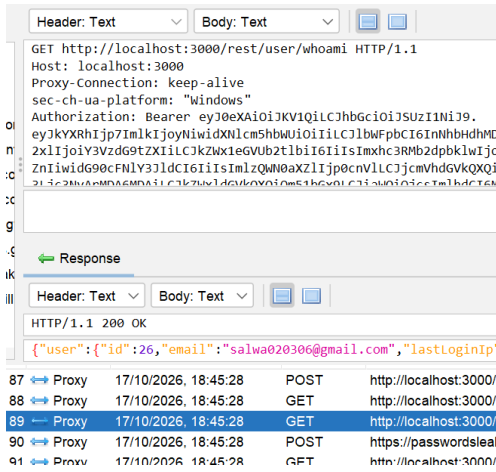
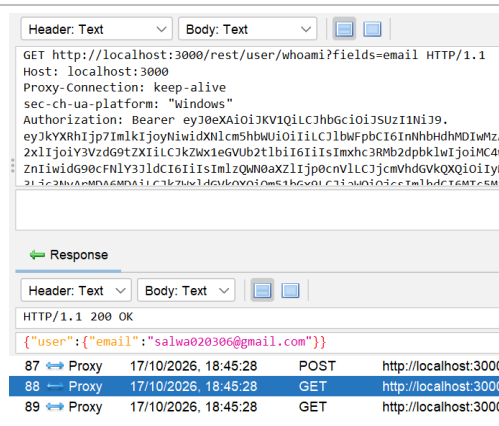
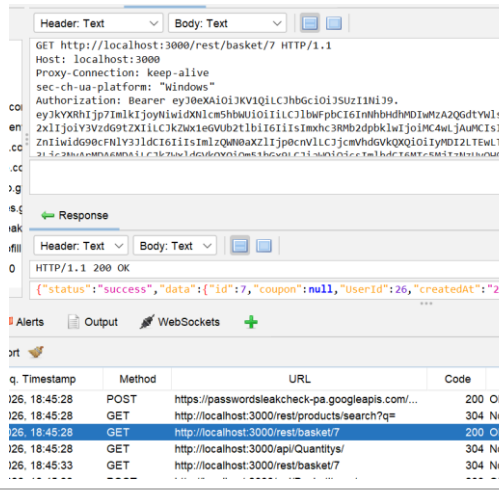
Komponen	Kriteria utama	Bobot
Cakupan sistem	Jelas, sesuai alur yang diamati	10
Attack Surface Map	Minimal 10 entry point, didukung bukti History atau DevTools	20
DFD	Elemen lengkap dan bernomor, trust boundary benar	25
Threat Model STRIDE	Minimal 12 threat, kategori tepat, risk L × I konsisten, respons jelas	30
Refleksi dan kerapian	Pemahaman tepat, laporan rapi	15
Total		100

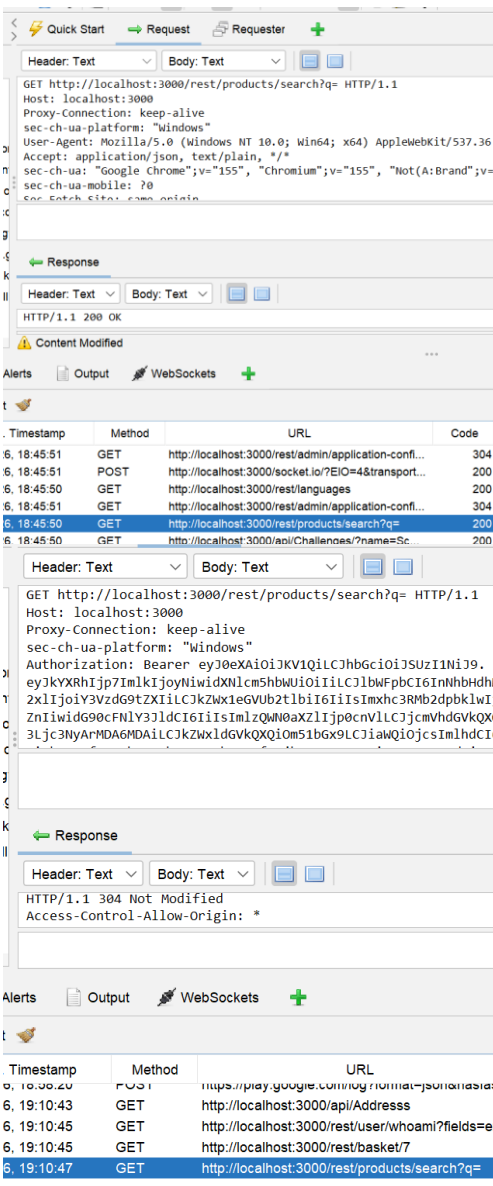
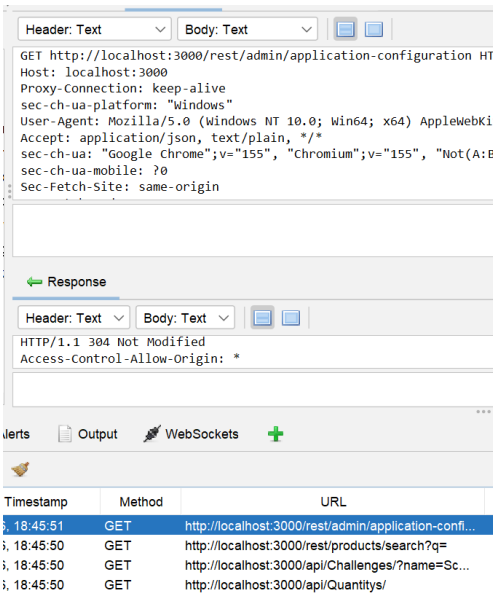
G. Pemecahan Masalah dan Referensi

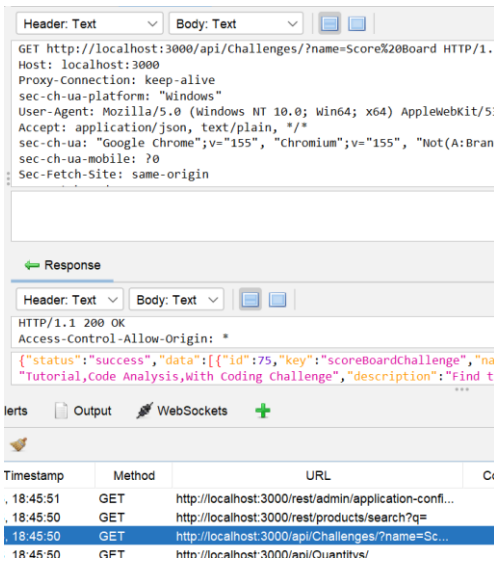
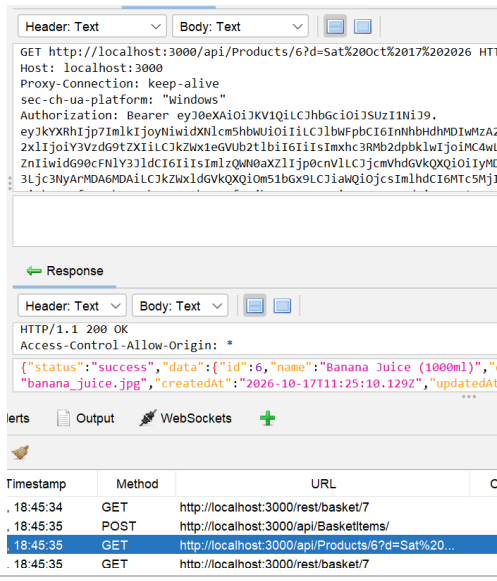
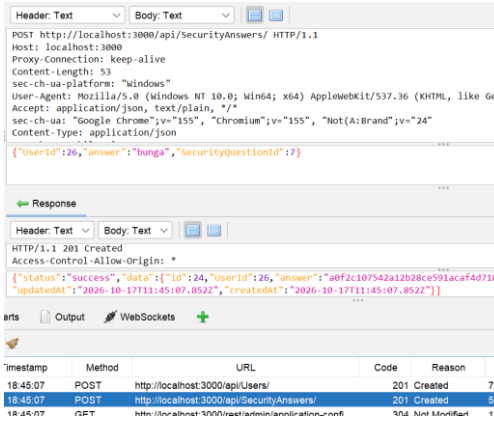
Masalah	Penyebab umum	Penanganan
Request tidak muncul di ZAP History	Browser melewati proxy untuk localhost	Gunakan browser dari Launch Browser pada ZAP.
Bingung menentukan trust boundary	Batas kepercayaan belum jelas	Tanyakan: siapa yang mengendalikan sisi ini? Browser pengguna tidak tepercaya.
Threat terlalu umum	Tidak menyebut aktor dan elemen	Tulis ulang: siapa, melakukan apa, pada elemen mana.

- Shostack, A. Threat Modeling: Designing for Security. Wiley.
- OWASP Threat Modeling Cheat Sheet (cheatsheetseries.owasp.org).
- NIST SP 800-218, Secure Software Development Framework (SSDF).
- Microsoft, STRIDE dan Security Development Lifecycle (learn.microsoft.com).
- NIST SP 800-30 dan OWASP Risk Rating Methodology (rujukan skala risk).

Lampiran A. Template Attack Surface Map

ID	Entry point (URL / form)	Metode	Data masuk	Perlu login	Catatan / bukti
AS-01	/rest/user/login	POST	email, password	Ya	
AS-02	/rest/user/whoami	GET	token autentikasi	Tidak	
AS-03	/rest/user/ whoami?fields=email	GET	token, parameter fields	Ya	
AS-04	/rest/basket/7	GET	ID basket, token	Ya	

ID	Entry point (URL / form)	Metode	Data masuk	Perlu login	Catatan / bukti
AS-05	/rest/products/search?q=	GET	kata kunci pencarian	tidak	
AS-06	/rest/admin/application-configuration	GET	token/request	ya	
AS-07	/api/Address	GET	token autentikasi	Ya	

ID	Entry point (URL / form)	Metode	Data masuk	Perlu login	Catatan / bukti
AS-08	/api/address/8	GET	ID alamat, token	Ya	
AS-09	/api/Deliveries	GET	token/autentikasi	Ya	
AS-10	/api/Challenges/?name=	GET	nama challenge	ya	
AS-11	/api/Products/6?d=Sat%20Oct%2017%202026	GET	ID produk, parameter d	Tidak	
AS-12	/api/SecurityAnswers/	GET	token/autentikasi	ya	

Lampiran B. Template Elemen DFD

ID	Tipe	Nama elemen	Trust zone
E1	External entity	Pelanggan (browser)	Tidak tepercaya
P1	Process	Login dan sesi	Server
P2	Process	Pengelolaan keranjang	Server
P3	Process	Checkout / pembuatan pesanan	Server
D1	Data store	Data akun pengguna	Server
D2	Data store	Data keranjang	Server
D3	Data store	Data pesanan	Server
D4	Data store	Data alamat pengiriman	Server
F1	Data flow	Kredensial login	Browser → Server
F2	Data flow	Token/sesi autentikasi	Server → Browser
F3	Data flow	Data akun	Login dan sesi ↔ Data akun
F4	Data flow	Permintaan/data keranjang	Browser ↔ Server
F5	Data flow	Data keranjang	Pengelolaan keranjang ↔ Data keranjang
F6	Data flow	Data checkout	Browser → Server
F7	Data flow	Data pesanan	Checkout ↔ Data pesanan
F8	Data flow	Data alamat pengiriman	Checkout ↔ Data alamat

Lampiran C. Template Threat Model

ID	Elemen	STRIDE	Threat	Aset / R-xx	L	I	Skor	Respons dan mitigasi
TM-01	P1 (F1)	S	Penyerang mencoba banyak password pada login	A-01 / R-01	4	4	16 (Kritis)	Mitigate: rate limiting, lockout, MFA
TM-02	P1 (F1)	S	Penyerang menggunakan kredensial milik pengguna lain untuk masuk ke akun	A-01 / R-01	3	5	15 (Kritis)	Mitigate: MFA, rate limiting, kontrol autentikasi
TM-03	P2 (F4)	T	Penyerang mengubah parameter request keranjang untuk memanipulasi data keranjang	A-02 / R-02	3	4	12 (Tinggi)	Mitigate: validasi server-side dan pemeriksaan integritas
TM-04	P3 (F6)	T	Penyerang memodifikasi data checkout sebelum diproses server	A-03 / R-03	3	5	15 (Kritis)	Mitigate: validasi input dan pemeriksaan integritas
TM-05	P3 (F7)	R	Pengguna menyangkal pernah melakukan pemesanan karena aktivitas tidak tercatat dengan baik	A-03 / R-03	2	4	8 (Sedang)	Mitigate: audit log dan pencatatan aktivitas
TM-06	P1 (F1)	I	Pesan error login dapat membocorkan informasi yang seharusnya tidak diketahui pengguna	A-01 / R-01	3	3	9 (Sedang)	Mitigate: sanitasi pesan error dan hindari informasi sensitif
TM-07	D1	I	Data akun pengguna dapat diakses oleh pihak yang tidak berwenang	A-01 / R-01	3	5	15 (Kritis)	Mitigate: access control dan authorization
TM-08	P1	D	Penyerang mengirim banyak request ke endpoint login sehingga layanan terganggu	A-01 / R-01	3	4	12 (Tinggi)	Mitigate: rate limiting dan monitoring
TM-09	P3	D	Penyerang mengirim request checkout secara berulang untuk membebani server	A-03 / R-03	3	4	12 (Tinggi)	Mitigate: rate limiting dan pembatasan request

ID	Elemen	STRIDE	Threat	Aset / R-xx	L	I	Skor	Respons dan mitigasi
TM-10	P2 / D2	E	Pengguna mencoba mengakses keranjang yang bukan miliknya	A-02 / R-02	3	5	15 (Kritis)	Mitigate: authorization dan ownership check
TM-11	D4 / F8	I	Data alamat pengiriman pengguna dapat diakses oleh pihak yang tidak berwenang	A-04 / R-04	3	5	15 (Kritis)	Mitigate: authorization dan access control
TM-12	P3 / D3	E	Pengguna biasa mencoba mengakses fungsi pengelolaan pesanan yang membutuhkan hak khusus	A-03 / R-03	3	5	15 (Kritis)	Mitigate: role-based authorization